Симуляційна рольова гра CISO vs CEO: Межа компромісу

Кейс 1: Shadow AI: Витік Personally Identifiable Information перед раундом інвестицій

🏢 Про компанію:

«PayStream» — FinTech-стартап. Завтра — презентація інвесторам Series B ($20 млн).

⚠ Ситуація:

DLP-система зафіксувала, що розробники протягом місяця вставляли в публічні AI-чатботи код флагманського продукту та тестовий дамп бази: 12 000 записів клієнтів з ЄС, де були ПІБ інвесторів, їх пошти, номери рахунків. В інвестиційній угоді є пункт: «відсутність нерозкритих інцидентів». Політики використання ШІ в компанії немає.

Матриця ролей, цілей, червоних лідей:

Роль	Основне завдання	Ключові цілі	Червоні лінії
CISO	Забезпечити безпечне використання технологій та відреагувати на витік.	• Запропонувати закупівлю Enterprise AI з підписаним DPA (захист даних). • Кваліфікувати подію як Інцидент інформаційної безпеки та зберегти логи.	• Погодитись на використання публічних AI без договорів. • Видалити логи DLP, щоб приховати сліди витоку.
CEO	Успішно закрити раунд інвестицій.	• Провести презентацію інвесторам за графіком.	• Скасувати презентацію інвесторам. • Підписати гарантію про відсутність іцидентів

Роль	Основне завдання	Ключові цілі	Червоні лінії
		• Розкрити інвесторам факт інциденту контрольовано в межах due diligence	
Head of Product	Зберегти швидкість розробки.	• Отримати бюджет на корпоративний ШІ-інструмент до кінця тижня. • Уникнути звільнення своїх розробників.	• Заборонити використання будь-якого ШІ назавжди. • Змусити команду переписувати весь код з нуля.
Legal / Compliance	Захист від штрафів регуляторів.	• Підготувати повідомлення регулятору GDPR протягом 72 годин. • Розробити політику використання ШІ в компанії.	• Приховати витік персональних даних клієнтів ЄС від регулятора.
PR Director	Захист репутації на ринку.	• Підготувати Q&A документ для продажів та підтримки на випадок витоку інфи. • Сфокусувати презентацію на інноваційності команди.	• Видавати недостовірну інформацію у публічний простір

💡 Best Practices (Розбір):

- Витік Personally Identifiable Information в публічну LLM — це інцидент. За GDPR регулятора треба повідомити протягом 72 годин.
- Повна заборона ШІ призводить до Shadow IT. Правильний компроміс: корпоративний тариф із Data Processing Agreement і вимкненим навчанням на даних клієнта.
- Приховування інциденту від інвесторів — це fraud (шахрайство). Контрольоване розкриття з планом дій (remediation) — єдиний законний шлях.

Кейс 2: Атака на ланцюг постачання (Third-Party Risk)

🏢 Про компанію:

«UaCart» — національний маркетплейс (50 000 замовлень/добу). Завтра великий розпродаж.

⚠ Ситуація:

SaaS-провайдер логістики перестав відповідати. Неофіційно — у них Ransomware. Ваші системи підключені до них через API токени. Провайдер ігнорує SLA і повідомляє, що на даний момент збій і скоро все підніменться

Матриця ролей та цілей:

Роль	Основне завдання	Ключові цілі	Червоні лінії
CISO	Ізоляція інфраструктури за Zero Trust	• Негайно відкликати API токени провайдера. • Перевести системи моніторингу в посилений режим.	• Залишити API-з'єднання активним до провайдера.
CEO	Мінімізація збитків від простою.	• Запустити план безперервності бізнесу (BCP) для ручної обробки замовлень. • Продовжити прийом замовлень на сайті (навіть із затримкою доставки).	• Повністю зупинити роботу бізнесу на 24+ години. • Виправдовуватись перед клієнтами, що «нас зламали» (зламали не вас).
Head of Operations	Логістика та відвантаження.	• Використати вчорашні резервні копії накладних для відвантаження вручну. • Встановити дедлайн для провайдера, після якого	• Вимагати від CISO залишити API відкритим попри ризик. • Передати бази клієнтів через особисті

Роль	Основне завдання	Ключові цілі	Червоні лінії
		переходимо на резервну службу.	Telegram/Drive для пришвидшення.
Legal	Захист інтересів та страхування.	• Повідомити страхову компанію в межах 24 годин (вимога полісу). • Зафіксувати порушення SLA з боку провайдера письмово.	• Пропустити термін подачі заяви до страхової. • Взяти юридичну провину за затримки на себе, а не на форс-мажор.

💡 **Best Practices:**

- В умовах компрометації підрядника діє принцип Zero Trust: API-токени відкликаються одразу, не чекаючи підтвердження злому.
- Бізнес має виживати завдяки плану безперервності (BCP — ручне відвантаження), а не ризикуючи всією мережею.
- Страхування в сфері кіберзахисту вимагає негайного повідомлення (зазвичай 24 год). Порушення цього терміну анулює виплати.

Кейс 3: Недоступний адміністратор та підозріла активність

🏢 Про компанію:

«SkyShield» — defense-tech стартап. Розробляють софт для дронів. Реліз оновлення для ЗСУ — через 36 годин.

⚠️ Ситуація:

Єдиний DevOps-інженер, який має root-доступ до хмарної інфраструктури, перебуває в зоні без зв'язку. Паролі ніде не задокументовані. Сьогодні SIEM-система показує: з сервісного токена інженера з невідомої закордонної IP-адреси почалося масове викачування телеметрії. Це може бути його автоматичний скрипт, але є ризик зламу.

Матриця ролей та цілей:

Роль	Основне завдання	Ключові цілі	Червоні лінії
CISO	Запобігання витоку військових даних.	• Негайно відкликати скомпрометований токен та розірвати сесію. • Ініціювати офіційну процедуру відновлення доступу (Recovery) через хмарного провайдера.	• Дозволити невідомій IP-адресі завершити викачування бази. • Використовувати неофіційні бекдори для доступу в систему.
CEO	Виконання оборонного контракту.	• Підготувати офіційний лист замовнику про можливу затримку релізу. • Сформувати бюджет на впровадження системи управління доступами (PAM).	• Зірвати військовий контракт без попередження замовника. • Наказати IT-відділу зламувати власні сервери.
Head of Product	Відновлення інфраструктури.	• Створити нову інфраструктуру з бекапів паралельно, поки йде відновлення root-доступу. • Призначити мінімум двох адміністраторів на майбутнє.	• Переписувати архітектуру з нуля. • Звинувачувати відсутнього інженера без результатів розслідування.
Legal / Compliance	Дотримання умов держконтракту.	• Повідомити замовника та уповноважені органи про підозру на інцидент (вимога контракту). • Оформити відсутність інженера як форс-мажор документально.	• Приховати підозру на витік даних від Міноборони. • Підробити цифрові підписи інженера для скидання паролів.

💡 Best Practices:

- Активна невідома сесія завжди вбивається. Дані військового призначення цінніші за кілька годин простою.
- Доступ до інфраструктури відновлюється виключно через легальні процедури хмарного провайдера з підписом директора, а не через хакінг.
- Державні оборонні контракти вимагають прозорого звітування про інциденти. Приховування — це кримінал.

💡 Best Practices (Розбір):

- Вимоги спецслужб у разі загрози національній безпеці та критичній інфраструктурі є пріоритетними.
- Ізоляція підозрілого сегменту замість повного шатдауну (де це технічно можливо і погоджено зі слідством) — хороший компроміс для BCP.
- Відкрита комунікація з регулятором захищає ліцензію, але комунікація в маси має бути виваженою, щоб не зупинити донати.
